

CircuLink Admin Permissions and Review Guide

1. Purpose

This document defines CircuLink’s account roles, admin permissions, review workflow, data access boundaries, and database design recommendations.

It covers:

- Second-hand marketplace listings
- Donation listings
- club-operation workflows
- Buy42 / partner handover workflows
- Admin moderation and data governance
- AI-assisted review and human review boundaries

The goal is to keep the platform safe for the DKU community while minimizing unnecessary access to personal data.

2. Account Roles

CircuLink should support four primary account types.

Role	Core Positioning	Main Purpose
USER	Regular platform user	Buy, sell, donate, claim, and message within the platform
CLUB_OPERATOR	Student organization / operations account	Approve donations, support offline collection, and coordinate donation operations
BUY42_PARTNER	External or partner receiver account	View assigned donation descriptions and choose whether to accept
ADMIN	Platform administrator	Manage users, roles, listings, reviews, data exports, and system governance

3. Permission Principles

CircuLink should follow these principles:

- Use least privilege by default.
- Give each role only the data needed for its work.
- Separate second-hand marketplace data from donation operations data.
- Do not expose private chats unless required for a reported dispute or safety investigation.
- Do not expose full user identity fields unless operationally necessary.
- Do not share raw personal data with partners.
- Keep all admin and partner operations auditable.
- AI can assist with review, but human reviewers own final enforcement decisions.
- Research exports must be anonymized or aggregated unless explicit consent / IRB approval exists.

4. Role Permission Matrix

Feature	Admin	Club Operator	Regular User	Buy42 Partner
Buy second-hand items	Yes	Yes	Yes	No
Publish second-hand listings	Yes	Yes	Yes	No
Publish donation listings	Yes	Yes	Yes	No
Upload images	Yes	Yes	Yes	No
Send platform messages	Yes	Yes	Yes	Only for assigned donation handovers, if needed
View own listings	Yes	Yes	Yes	No
View donation list	All	Operations-related only	Own donations only	Assigned pending / received donations only
Choose whether to accept donation	Yes	Assist only	No	Yes
Review listings	Yes	Donation-related only	No	No
Hide or archive违规 listings	Yes	Assist or flag only	Own listings only	No
Manage user roles	Yes	No	No	No
Export research data	Yes, with restrictions	No	No	No
View audit logs	Yes	Limited own-operation logs	No	No
View private chats	Exception only	No	Own chats only	No

5. Data Access Matrix

Data Type	Admin	Club Operator	Regular User	Buy42 Partner
Listing title / description / price / category	All	Relevant operations only	Own and public active listings	No
Donation images / text description / donation category	All	Relevant donation records	Own and public active donations	Assigned donation description only
User email / NetID / real name	Necessary cases only	Only if required for handover	Own profile only	No
Contact information	Necessary cases only	Minimal required contact fields	Own information only	No
Transaction records	All, with audit trail	No second-hand transaction data	Own transactions only	No
Donation handover records	All	Relevant records	Own donation records	Assigned records only
Private messages	Exception only	No	Own messages only	No
AI review results	All	Relevant donation-related results	No	No
Audit logs	All	Own operation logs if needed	No	No
Research exports	Anonymized / aggregated by default	No	No	No

6. Publishing and Editing Policy

For the first stable version, CircuLink should use a simple and safer rule:

> Approved listings and donations cannot be edited in place. Users can archive, mark sold / claimed, or submit a new listing.

Allowed after approval:

- Mark a second-hand listing as SOLD
- Mark a donation as CLAIMED, RESERVED, or completed according to workflow
- Archive / take down own listing
- Submit a new listing or donation if content needs to change

Not allowed after approval:

- Edit title
- Edit description
- Edit price
- Edit category
- Replace or add images

- Change donation conditions
- Convert donation into paid listing

This avoids the common bypass pattern where a user posts safe content, passes review, and later edits it into risky content.

7. Review Workflow

7.1 New Second-Hand Listing

- 1 User submits a new listing.
- 2 System validates required fields, category, price, image count, and content rules.
- 3 AI reviews text and images for risk.
- 4 Decision engine routes the submission:
 - Low risk: publish directly to the website to reduce manual intervention
 - Flagged by rules or AI: human review
 - High risk: hidden pending review
- 1 Human reviewer approves, rejects, requests changes, or archives.
- 2 User receives a clear result and reason.

7.2 New Donation

Donation should be stricter than regular marketplace listings.

- 1 User submits donation.
- 2 System enforces donation-specific rules. The donation page only contains images, text description, and donation category, so it does not have a price field by default.
 - No deposit, payment, external transfer, or disguised sale.
 - Required pickup / handover information must be present.
- 1 AI checks for unsafe items, suspicious language, image mismatch, and private-payment signals.
- 2 Low-risk donation may be approved.
- 3 Donations flagged by rules or AI go to Admin or club-operation review.
- 4 club-operation can directly approve donation submissions.

5 Approved donation becomes visible or enters the collection workflow.

7.3 Existing Listing or Donation

Users should not edit approved content directly.

If the user wants to change core content:

- 1 Archive the current listing / donation.
- 2 Submit a new listing / donation.
- 3 New submission goes through the normal review process.

This keeps the review model simple and auditable.

8. Review Decision Rules

Case	Suggested Action
Complete low-risk second-hand listing	Auto approve and publish directly
Low-risk donation with clear image and no payment signals	Auto approve or direct club-operation approval
Missing required fields	Block submission and ask user to fix
Donation description mentions deposit, exchange, payment, or private transfer	Human review, likely reject
High-value electronics	Human review
Food, medicine, cosmetics, batteries, sharp tools, or unsafe items	Human review
External payment, QR code, off-platform transaction language	Hide pending review
Repeated suspicious posts by same user	Escalate to Admin
Clearly prohibited content	Hide immediately and require Admin decision

9. AI and Human Review Boundary

AI should do:

- Risk scoring
- Text and image pre-screening

- Category / image consistency checks
- Scam, external payment, and unsafe item detection
- Review summaries for human reviewers

AI should not do:

- Final account bans
- Final severe enforcement
- Final rejection for ambiguous cases without human confirmation
- Private data export decisions

Human reviewers should do:

- Final rejection
- Account warnings or restrictions
- Dispute handling
- Appeal decisions
- Sensitive category decisions
- Any decision involving private data or partner access

10. Status Model

Recommended second-hand listing statuses:

DRAFT
PENDING_REVIEW
ACTIVE
NEEDS_CHANGES
REJECTED
SOLD
ARCHIVED
HIDDEN

Recommended donation statuses:

DRAFT
PENDING_REVIEW
ACTIVE
RESERVED

CLAIMED
COLLECTED_BY_CLUB
RECEIVED_BY_BUY42
DONATED
REJECTED
ARCHIVED
HIDDEN

Donation workflow should be modeled as an independent table rather than long-term sharing the marketplace Item table. Shared image upload utilities can still be reused, but donation master data, status transitions, and handovers should be modeled separately.

11. Database Design Recommendations

11.1 Roles

Current schema has User.role. That is acceptable for MVP, but a role history table is better for governance.

Recommended table:

user_roles

Suggested fields:

- id
- user_id
- role
- granted_by
- granted_reason
- expires_at
- revoked_at
- created_at
- updated_at

This supports temporary club-operation and Buy42 access.

11.2 Review Queue

Recommended table:

review_queue

Suggested fields:

- id
- target_type: listing / donation / image / user
- target_id
- submission_type: new_listing / new_donation
- submitted_by
- status: pending / approved / rejected / needs_changes / hidden / escalated
- risk_level: low / medium / high
- ai_summary
- ai_flags
- assigned_reviewer_id
- reviewed_by
- review_reason
- created_at
- reviewed_at
- updated_at

Because editing is not allowed after approval, this table does not need complex old-version / new-version diffs in the MVP. Human review only handles submissions flagged by system rules or AI; low-risk submissions should generally publish directly.

11.3 Review Decisions

Recommended table:

review_decisions

Suggested fields:

- id
- review_id
- decision: approve / reject / request_changes / hide / escalate

- reviewer_id
- reason_code
- comment
- created_at

This preserves why an action was taken.

11.4 AI Review Results

Recommended table:

ai_review_results

Suggested fields:

- id
- review_id
- model_name
- risk_score
- risk_level
- flags
- summary
- raw_output
- created_at

Access to raw_output should be restricted because it may include user-submitted content.

11.5 Admin Audit Logs

Recommended table:

admin_audit_logs

Suggested fields:

- id
- actor_id

- actor_role
- action
- target_type
- target_id
- before
- after
- ip_address
- user_agent
- created_at

Must log:

- Role assignment or removal
- Review decisions
- Listing hide / archive / delete
- Donation status changes
- Buy42 receipt confirmation
- Sensitive data views
- Data exports

11.6 Data Export Logs

Recommended table:

data_export_logs

Suggested fields:

- id
- exported_by
- export_type
- fields_included
- anonymized

- purpose
- approved_by
- created_at

Exports should be anonymized by default.

11.7 Donation Handovers

Recommended table:

donation_handovers

Suggested fields:

- id
- donation_id
- club_operator_id
- buy42_account_id
- handover_status
- pickup_time
- handover_location
- received_at
- receipt_image_url
- notes
- created_at
- updated_at

Buy42 should access this workflow view rather than the full admin dashboard. Buy42 can see donation images, text description, donation category, and necessary handover status, and can choose whether to accept; Buy42 cannot see user contact information.

12. Admin Safety Controls

Sensitive admin actions should require stronger controls:

- Role changes require Admin permission.

- Assigning another Admin requires approval from one existing Admin and must be logged.
- Data export should require purpose text and audit logging.
- Deleting or hiding listings should record reason codes.
- Viewing sensitive user identity fields should be logged.
- Private chats should not be visible by default; they can only be reviewed when there is an existing user report, dispute, or safety incident, and the access must be logged.
- Buy42 accounts should not access general admin dashboards.
- Club operation accounts should not access database, server, GitHub secrets, or full user exports.
- Temporary accounts should expire automatically.

13. User Notification Rules

Users should receive clear status updates:

- Submitted for review
- Approved
- Rejected with reason
- Needs changes
- Hidden for safety review
- Donation reserved / claimed / handed over / received

Messages should be specific enough to help users fix issues, but should not reveal exact abuse-detection rules.

14. Appeals and Disputes

CircuLink should support a basic appeal process:

- User can appeal a rejection or hidden listing.
- Appeal goes to Admin, not AI-only review.
- Admin can uphold, reverse, or request changes.
- All appeal decisions should be logged.

15. Implementation Todo List

Phase 1: MVP Governance

- ☐ Finalize role names: USER, CLUB_OPERATOR, BUY42_PARTNER, ADMIN.
- ☐ Add these role values to backend validation.
- ☐ Decide whether to keep single User . role for MVP or add user_roles.
- ☐ Define listing and donation statuses.
- ☐ Block editing of approved core listing fields.
- ☐ Allow users to archive, mark sold, or submit a new listing.
- ☐ Add review status to listing / donation creation flow.
- ☐ Create an Admin review dashboard for listings and donations flagged by rules / AI.
- ☐ Add clear user-facing review status messages.

Phase 2: Review System

- ☐ Add review_queue.
- ☐ Add review_decisions.
- ☐ Add reason codes for approve / reject / request changes / hide.
- ☐ Route new second-hand listings flagged by rules / AI into human review.
- ☐ Route new donations flagged by rules / AI into human review.
- ☐ Allow Admin to approve / reject / hide any review item.
- ☐ Allow club-operation to directly approve donations.
- ☐ Prevent Buy42 from reviewing platform content.

Phase 3: Partner and Donation Workflow

- ☐ Add donation_handovers.
- ☐ Build club-operation donation operations view.
- ☐ Build Buy42 limited handover view.
- ☐ Allow Buy42 to view assigned donation descriptions, categories, and images, and choose whether to accept.
- ☐ Prevent Buy42 from viewing user contact information.

- □ Log Buy42 receipt confirmation.
- □ Prevent Buy42 from viewing marketplace transactions or full user profiles.

Phase 4: AI-Assisted Review

- □ Define AI review input fields.
- □ Define AI output schema: risk score, risk level, flags, summary.
- □ Add ai_review_results.
- □ Use AI to pre-screen new listings and donations.
- □ Auto-approve only clearly low-risk submissions.
- □ Send medium and high-risk submissions to human review.
- □ Prevent AI-only account bans or severe enforcement.

Phase 5: Admin Security and Audit

- □ Add admin_audit_logs.
- □ Log role changes.
- □ Log review decisions.
- □ Log listing hide / archive / deletion.
- □ Log sensitive data views.
- □ Log data exports.
- □ Add two-step confirmation for data export; Admin assignment requires one existing Admin approval and audit logging.
- □ Add role expiration for club-operation and Buy42 accounts.
- □ Add a periodic access review process.

Phase 6: Research Data Governance

- □ Define exportable research fields.
- □ Remove direct identifiers from default exports.
- □ Add data_export_logs.
- □ Require export purpose.

- □ Require Admin approval for non-anonymized exports.
- □ Document consent / IRB requirements.

16. Confirmed Product Decisions

- Only content flagged by system rules or AI requires human review; low-risk publishing should generally appear directly on the website.
- REACH_OPERATOR is no longer used; use CLUB_OPERATOR / club-operation instead.
- club-operation can directly approve donation submissions.
- The donation page only contains images, text description, and donation category; it does not have a price field.
- Buy42 cannot see user contact information; it can only see donation description, category, images, handover status, and choose whether to accept.
- Private chat review requires an existing user report, dispute, or safety incident.
- Admin assignment requires approval from one existing Admin and must be audit logged.
- Donation workflow should be modeled in an independent table rather than long-term sharing the marketplace Item table.